



Veracode Detailed Report
Application Security Report
As of 10 Sep 2026

Prepared for:	State of North Carolina Department of Health and Human Services
Prepared on:	September 10, 2026
Application:	cwis-genai
Sandbox:	Validation Scans
Industry:	Not Specified
Business Criticality:	BC3 (Medium)
Required Analysis:	Static
Type(s) of Analysis Conducted:	Static
Scope of Static Scan:	2 of 2 Modules Analyzed

Inside This Report

Executive Summary	1
Summary of Flaws by Severity	1
Action Items	1
Flaw Types by Category	3
Policy Summary	5
Findings & Recommendations	6
Methodology	

While every precaution has been taken in the preparation of this document, Veracode, Inc. assumes no responsibility for errors, omissions, or for damages resulting from the use of the information herein. The Veracode platform uses static and/or dynamic analysis techniques to discover potentially exploitable flaws. Due to the nature of software security testing, the lack of discoverable flaws does not mean the software is 100% secure.

Veracode Detailed Report
Application Security Report
As of 10 Sep 2026

Veracode Level: VL2
Rated: Sep 10, 2026

Application: cwis-genai
Target Level: None

Business Criticality: Medium
Published Rating: B

Scans Included in Report

Static Scan	Dynamic Scan	Manual Penetration Test
cwis-genai-main-10 Sep 2026 Static Score: 73 Completed: 9/10/26	Not Included in Report	Not Included in Report

Executive Summary

This report contains a summary of the security flaws identified in the application using manual penetration testing, automated static and/or automated dynamic security analysis techniques. This is useful for understanding the overall security quality of an individual application or for comparisons between applications.

Application Business Criticality: BC3 (Medium)

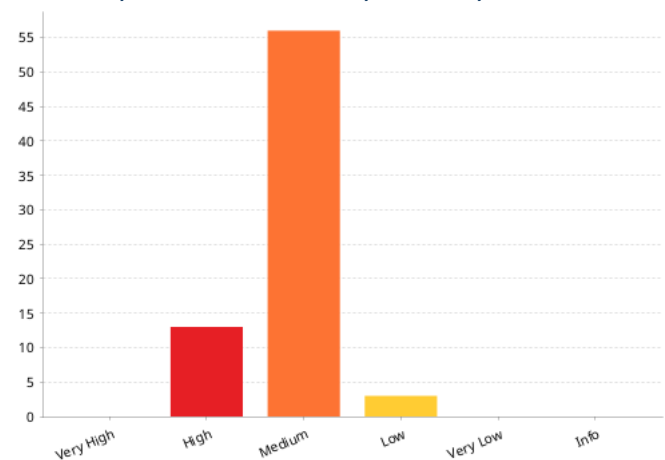
Impacts:Operational Risk (Low), Financial Loss (Medium)

An application's business criticality is determined by business risk factors such as: reputation damage, financial loss, operational risk, sensitive information disclosure, personal safety, and legal violations. The Veracode Level and required assessment techniques are selected based on the policy assigned to the application.

Analyses Performed vs. Required

	Any	Static	Dynamic	Manual Penetration Test
Performed:		●	○	○
Required:	○	●	○	○

Summary of Flaws Found by Severity



Action Items:

Veracode recommends the following approaches ranging from the most basic to the strong security measures that a vendor can undertake to increase the overall security level of the application.

Required Analysis

- ➔ Your policy requires periodic Static Scan. Your next analysis must be completed by 12/10/26. Please submit your application for Static Scan by the deadline and remediate the required detected flaws to conform to your assigned policy.

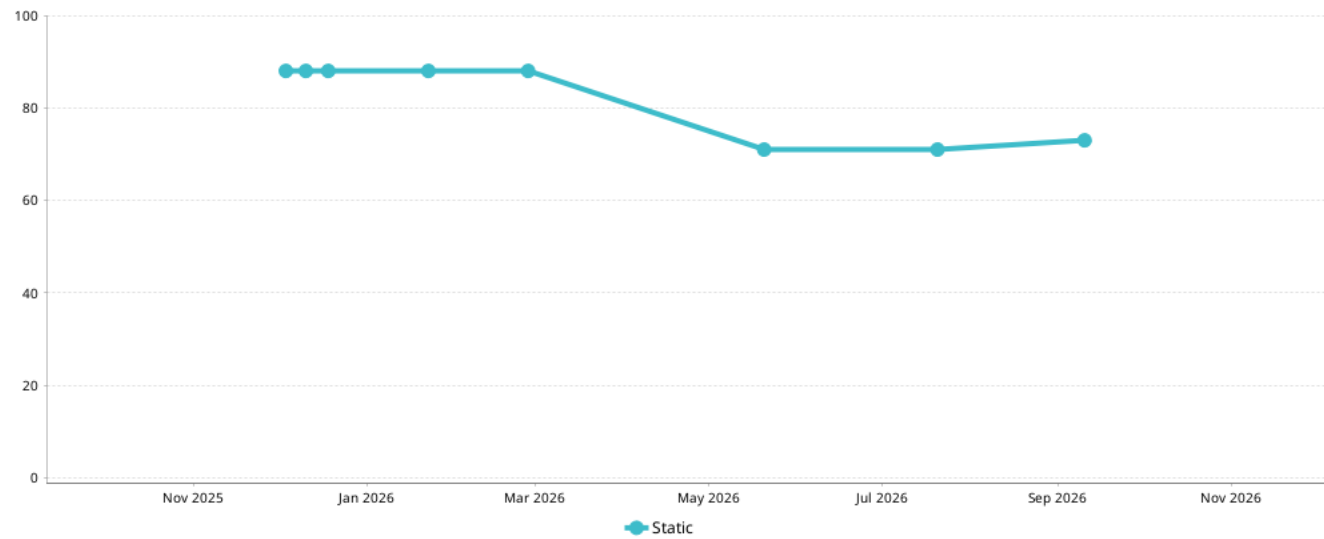
Flaw Severities

- High severity flaws and above must be fixed for policy compliance.

Longer Timeframe (6 - 12 months)

- Certify that software engineers have been trained on application security principles and practices.

Application Trend Data



Scope of Static Scan

The following modules were included in the static scan because the scan submitter selected them as entry points, which are modules that accept external data.

Engine Version: 20260902181802

The following modules were included in the application scan:

Module Name	Compiler	Operating Environment	Engine Version
JS files within cwis-genai-main.zip	JAVASCRIPT_5_1	JavaScript	20260902181802
Python files within cwis-genai-main.zip	Python	Python	20260902181802

Flaw Types by Severity and Category

Static Scan Security Quality Score = 73 (+2) from prior scan			
Very High	0		
High	13	(+5)	
Credentials Management	1	(-1)	
Cross-Site Scripting (XSS)	12	(+6)	
Medium	56	(-37)	
Authorization Issues	2	(+1)	
CRLF Injection	42	(-42)	
Cryptographic Issues	3		
Directory Traversal	7	(+3)	
Insufficient Input Validation	2	(+1)	

Static Scan Security Quality Score = 73 (+2) from prior scan			
Low	3	(+2)	
Information Leakage	3	(+2)	
Very Low	0		
Informational	0		
Total	72	(-30)	

Policy Evaluation

Policy Name: DHHS-Standard-No-Criticals-Highs-SCA

Revision: 5

Policy Status: Not Assessed

Description: Standard Scan Policy - SAST & SCA - No Criticals or Highs

Rules

Rule type	Requirement	Findings	Status
Max Severity	High	Flaws found: 13	Did not pass

Software Composition Analysis Rules

Rule type	Requirement	Findings	Status
Disallow Vulnerabilities by Severity	High and Above Not Allowed	10 Components	Did not pass

Findings & Recommendations

Detailed Flaws by Severity

Very High (0 flaws)

No flaws of this type were found

High (13 flaws)

 **Fix Required by Policy**

 Credentials Management(1 flaw)

Description

Improper management of credentials, such as usernames and passwords, may compromise system security. In particular, storing passwords in plaintext or hard-coding passwords directly into application code are design issues that cannot be easily remedied. Not only does embedding a password allow all of the project's developers to view the password, it also makes fixing the problem extremely difficult. Once the code is in production, the password cannot be changed without patching the software. If a hard-coded password is compromised in a commercial product, all deployed instances may be vulnerable to attack, putting customers at risk.

One variation on hard-coding plaintext passwords is to hard-code a constant string which is the result of a cryptographic one-way hash. For example, instead of storing the word "secret," the application stores an MD5 hash of the word. This is a common mechanism for obscuring hard-coded passwords from casual viewing but does not significantly reduce risk. However, using cryptographic hashes for data stored outside the application code can be an effective practice.

Recommendations

Avoid storing passwords in easily accessible locations, and never store any type of sensitive data in plaintext. Avoid using hard-coded usernames, passwords, or hash constants whenever possible, particularly in relation to security-critical components. Store passwords out-of-band from the application code. Follow best practices for protecting credentials stored in alternate locations such as configuration or properties files.

Associated Flaws by CWE ID:

 Use of Hard-coded Credentials (CWE ID 798)(1 flaw)

Description

The software contains hard-coded credentials, such as a password or cryptographic key, which it uses for its own inbound authentication, outbound communication to external components, or encryption of internal data.

Effort to Fix: 4 - Simple design error. Requires redesign and up to 5 days to fix.

Instances found via Static Scan

	Flaw Id	Module #	Class #	Module	Location	Fix By
NEW 	222	2	-	Python files within cwis-genai-main.zip	/.../api/db/activity.py 508	9/10/26

→ Cross-Site Scripting (XSS)(12 flaws)

Description

Cross-site scripting (XSS) attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user. Flaws that allow these attacks to succeed occur whenever a web application uses untrusted data in the output it generates without validating or encoding it. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise sensitive information, with new attack vectors being discovered on a regular basis. XSS is also commonly referred to as HTML injection.

XSS vulnerabilities can be either persistent or transient (often referred to as stored and reflected, respectively). In a persistent XSS vulnerability, the injected code is stored by the application, for example within a blog comment or message board. The attack occurs whenever a victim views the page containing the malicious script. In a transient XSS vulnerability, the injected code is included directly in the HTTP request. These attacks are often carried out via malicious URLs sent via email or another website and requires the victim to browse to that link. The consequence of an XSS attack to a victim is the same regardless of whether it is persistent or transient; however, persistent XSS vulnerabilities are likely to affect a greater number of victims due to its delivery mechanism.

Recommendations

Several techniques can be used to prevent XSS attacks. These techniques complement each other and address security at different points in the application. Using multiple techniques provides defense-in-depth and minimizes the likelihood of a XSS vulnerability.

- * Use output filtering to sanitize all output generated from user-supplied input, selecting the appropriate method of encoding based on the use case of the untrusted data. For example, if the data is being written to the body of an HTML page, use HTML entity encoding. However, if the data is being used to construct generated Javascript or if it is consumed by client-side methods that may interpret it as code (a common technique in Web 2.0 applications), additional restrictions may be necessary beyond simple HTML encoding.
- * Validate user-supplied input using positive filters (white lists) to ensure that it conforms to the expected format, using centralized data validation routines when possible.
- * Do not permit users to include HTML content in posts, notes, or other data that will be displayed by the application. If users are permitted to include HTML tags, then carefully limit access to specific elements or attributes, and use strict validation filters to prevent abuse.

Associated Flaws by CWE ID:

→ Improper Neutralization of Script-Related HTML Tags in a Web Page (Basic XSS) (CWE ID 80)(12 flaws)

Description

This call contains a cross-site scripting (XSS) flaw. The application populates the HTTP response with untrusted input, allowing an attacker to embed malicious content, such as Javascript code, which will be executed in the context of the victim's browser. XSS vulnerabilities are commonly exploited to steal or manipulate cookies, modify presentation of content, and compromise confidential information, with new attack vectors being discovered on a regular basis.

Effort to Fix: 3 - Complex implementation error. Fix is approx. 51-500 lines of code. Up to 5 days to fix.

Recommendations

Use contextual escaping on all untrusted data before using it to construct any portion of an HTTP response. The escaping method should be chosen based on the specific use case of the untrusted data, otherwise it may not protect fully against the attack. For example, if the data is being written to the body of an HTML page, use HTML entity escaping; if the data is being written to an attribute, use attribute escaping; etc. When a web framework provides built-in support for automatic XSS escaping, do not disable it. Both the OWASP Java Encoder library for Java and the Microsoft AntiXSS library provide contextual escaping methods. For more details on contextual escaping, see https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html. In addition, as a best practice, always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

Instances found via Static Scan

	Flaw Id	Module #	Class #	Module	Location	Fix By
	159	1	-	Python files within cwis-genai-main.zip	/.../routers/v1/common/activity.py 79	8/12/26
	32	3	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../src/auth.tsx 22	8/12/26
	58	12	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 73	8/12/26
	55	9	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 109	8/12/26
	59	11	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 447	8/12/26
	31	10	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 486	8/12/26
	56	8	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 3636	8/12/26
	218	13	-	Python files within cwis-genai-main.zip	/.../routers/v1/aws/knowledge.py 142	8/12/26
	215	13	-	Python files within cwis-genai-main.zip	/.../routers/v1/aws/knowledge.py 360	8/12/26
	160	16	-	Python files within cwis-genai-main.zip	/.../routers/v1/common/projects.py 141	8/12/26
	163	19	-	Python files within cwis-genai-main.zip	/.../settings/security.py 278	8/12/26
NEW	221	20	-	JS files within cwis-genai-main.zip	/.../shared_index.tsx 3587	9/10/26

Medium (56 flaws)

→ Authorization Issues(2 flaws)

Description

Authorization is the process or method by which an application determines whether a user, service, or application has the necessary permissions to perform a requested action. Web applications often restrict access to specific content or functionality based on the user's role or privilege level. If authorization is not implemented properly, an attacker can manipulate a web site to gain access to data or functionality that should be protected.

Authorization should not be confused with authentication. Authentication is the process of verifying a user's identity, while authorization enforces what that user is permitted to do after they have successfully authenticated to the system.

Recommendations

Be sure that authorization is properly enforced at the server side for every action. Centralize authorization routines when possible. Follow the principle of least privilege when designing security controls.

Associated Flaws by CWE ID:

→ Improper Control of Resource Identifiers ('Resource Injection') (CWE ID 99)(2 flaws)

Description

The software allows untrusted input to control resource identifiers. This may enable an attacker to access or modify otherwise protected system resources.

Effort to Fix: 3 - Complex implementation error. Fix is approx. 51-500 lines of code. Up to 5 days to fix.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
219	6	-	Python files within cwis-genai-main.zip	/cwis-genai-main/.../aws_s3.py 193	
217	13	-	Python files within cwis-genai-main.zip	/.../routers/v1/aws/knowledge.py 211	

→ CRLF Injection(42 flaws)

Description

The acronym CRLF stands for "Carriage Return, Line Feed" and refers to the sequence of characters used to denote the end of a line of text. CRLF injection vulnerabilities occur when data enters an application from an untrusted source and is not properly validated before being used. For example, if an attacker is able to inject a CRLF into a log file, he could append falsified log entries, thereby misleading administrators or cover traces of the attack. If an attacker is able to inject CRLFs into an HTTP response header, he can use this ability to carry out other attacks such as cache poisoning. CRLF vulnerabilities primarily affect data integrity.

Recommendations

Apply robust input filtering for all user-supplied data, using centralized data validation routines when possible. Use output filters to sanitize all output derived from user-supplied input, replacing non-alphanumeric characters with their HTML entity equivalents.

Associated Flaws by CWE ID:

→ Improper Output Neutralization for Logs (CWE ID 117)(42 flaws)

Description

A function call could result in a log forging attack. Writing untrusted data into a log file allows an attacker to forge log entries or inject malicious content into log files. Corrupted log files can be used to cover an attacker's tracks or as a delivery mechanism for an attack on a log viewing or processing utility. For example, if a web administrator uses a browser-based utility to review logs, a cross-site scripting attack might be possible.

Effort to Fix: 2 - Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.

Recommendations

Avoid directly embedding user input in log files when possible. Sanitize untrusted data used to construct log entries by using a safe logging mechanism such as the OWASP ESAPI Logger, which will automatically remove unexpected carriage returns and line feeds and can be configured to use HTML entity encoding for non-alphanumeric data. Only write custom blacklisting code when absolutely necessary. Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
165	7	-	Python files within cwis-genai-main.zip	/.../eval_judge/bedrock_judge.py 310	
164	7	-	Python files within cwis-genai-main.zip	/.../eval_judge/bedrock_judge.py 319	
57	8	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../index.tsx 526	
210	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 271	
208	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 295	
207	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 307	
205	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 845	
203	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 849	
200	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1117	
198	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1176	
197	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1177	
196	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1178	
195	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1179	
194	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1180	
193	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1181	
192	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1182	
191	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1183	
190	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1201	
189	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1212	
188	17	-	Python files within	.../run_from_excel_bedrock.py 1225	

Flaw Id	Module #	Class #	Module	Location	Fix By
			cwis-genai-main.zip		
187	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1230	
186	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1298	
185	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1299	
184	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1336	
183	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1351	
182	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1353	
181	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1382	
180	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1394	
179	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1396	
178	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1397	
177	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1398	
176	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1399	
175	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1426	
174	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1462	
173	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1463	
172	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1464	
171	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1465	
170	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1471	
169	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1504	
168	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1505	
167	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1513	
166	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1554	

→ Cryptographic Issues(3 flaws)

Description

Applications commonly use cryptography to implement authentication mechanisms and to ensure the confidentiality and integrity of sensitive data, both in transit and at rest. The proper and accurate implementation of cryptography is extremely critical to its efficacy. Configuration or coding mistakes as well as incorrect assumptions may negate a large degree of the protection it affords, leaving the crypto implementation vulnerable to attack.

Common cryptographic mistakes include, but are not limited to, selecting weak keys or weak cipher modes, unintentionally exposing sensitive cryptographic data, using predictable entropy sources, and mismanaging or hard-coding keys.

Developers often make the dangerous assumption that they can improve security by designing their own cryptographic algorithm; however, one of the basic tenets of cryptography is that any cipher whose effectiveness is reliant on the secrecy of the algorithm is fundamentally flawed.

Recommendations

Select the appropriate type of cryptography for the intended purpose. Avoid proprietary encryption algorithms as they typically rely on "security through obscurity" rather than sound mathematics. Select key sizes appropriate for the data being protected; for high assurance applications, 256-bit symmetric keys and 2048-bit asymmetric keys are sufficient. Follow best practices for key storage, and ensure that plaintext data and key material are not inadvertently exposed.

Associated Flaws by CWE ID:

→ Improper Certificate Validation (CWE ID 295)(1 flaw)

Description

The SSL Certificate Details provide information about the certificate associated with the HTTPS server. This information describes important attributes of the certificate and should be reviewed for the correctness of the contact information, whether it is self-signed, and how soon it will expire. The Supported Ciphers provides information about each available encryption scheme available for each of the possible SSL/TLS protocols.

Effort to Fix: 2 - Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.

Recommendations

The expiration date for certificates should be monitored. New certificates should be available before the expiration date in order to maintain continuity of service and avoid downtime or displaying certificate expiration errors in users' web browsers.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
209	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 276	

➔ Insufficient Entropy (CWE ID 331)(2 flaws)

Description

Standard random number generators do not provide a sufficient amount of entropy when used for security purposes. Attackers can brute force the output of pseudorandom number generators such as rand().

Effort to Fix: 2 - Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.

Recommendations

If this random number is used where security is a concern, such as generating a session identifier or cryptographic key, use a trusted cryptographic random number generator instead.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
154	4	-	Python files within cwis-genai-main.zip	.../aws_bedrock_controller.py 47	
153	4	-	Python files within cwis-genai-main.zip	.../aws_bedrock_controller.py 86	

➔ Directory Traversal(7 flaws)

Description

Allowing user input to control paths used in filesystem operations may enable an attacker to access or modify otherwise protected system resources that would normally be inaccessible to end users. In some cases, the user-provided input may be passed directly to the filesystem operation, or it may be concatenated to one or more fixed strings to construct a fully-qualified path.

When an application improperly cleanses special character sequences in user-supplied filenames, a path traversal (or directory traversal) vulnerability may occur. For example, an attacker could specify a filename such as "../etc/passwd", which resolves to a file outside of the intended directory that the attacker would not normally be authorized to view.

Recommendations

Assume all user-supplied input is malicious. Validate all user-supplied input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using black lists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters and ensure that the end result is not dangerous.

Associated Flaws by CWE ID:

➔ External Control of File Name or Path (CWE ID 73)(7 flaws)

Description

This call contains a path manipulation flaw. The argument to the function is a filename constructed using untrusted input. If an attacker is allowed to specify all or part of the filename, it may be possible to gain unauthorized access to files on the server, including those outside the webroot, that would be normally be inaccessible to end users. The level of exposure depends on the effectiveness of input validation routines, if any.

Effort to Fix: 2 - Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.

Recommendations

Validate all untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. When using black lists, be sure that the sanitizing routine performs a sufficient number of iterations to remove all instances of disallowed characters.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
220	6	-	Python files within cwis-genai-main.zip	/cwis-genai-main/.../aws_s3.py 43	
206	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 844	
204	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 848	
202	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 918	
201	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1115	
199	17	-	Python files within cwis-genai-main.zip	.../run_from_excel_bedrock.py 1169	
212	18	-	Python files within cwis-genai-main.zip	/.../s3_helper.py 31	

→ Insufficient Input Validation(2 flaws)

Description

Weaknesses in this category are related to an absent or incorrect protection mechanism that fails to properly validate input that can affect the control flow or data flow of a program.

Recommendations

Validate input from untrusted sources before it is used. The untrusted data sources may include HTTP requests, file systems, databases, and any external systems that provide data to the application. In the case of HTTP requests, validate all parts of the request, including headers, form fields, cookies, and URL components that are used to transfer information from the browser to the server side application.

Duplicate any client-side checks on the server side. This should be simple to implement in terms of time and difficulty, and will greatly reduce the likelihood of insecure parameter values being used in the application.

Associated Flaws by CWE ID:

→ URL Redirection to Untrusted Site ('Open Redirect') (CWE ID 601)(2 flaws)

Description

A web application accepts a untrusted input that specifies a link to an external site, and uses that link to generate a redirect. This enables phishing attacks.

Effort to Fix: 2 - Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.

Recommendations

Always validate untrusted input to ensure that it conforms to the expected format, using centralized data validation routines when possible. Check the supplied URL against a whitelist of approved URLs or domains before redirecting.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
33	3	-	JS files within cwis-genai-main.zip	/cwis-genai-main/.../src/auth.tsx 22	
216	13	-	Python files within cwis-genai-main.zip	/.../routers/v1/aws/knowledge.py 211	

Low (3 flaws)

Information Leakage(3 flaws)

Description

An information leak is the intentional or unintentional disclosure of information that is either regarded as sensitive within the product's own functionality or provides information about the product or its environment that could be useful in an attack. Information leakage issues are commonly overlooked because they cannot be used to directly exploit the application. However, information leaks should be viewed as building blocks that an attacker uses to carry out other, more complicated attacks.

There are many different types of problems that involve information leaks, with severities that can range widely depending on the type of information leaked and the context of the information with respect to the application. Common sources of information leakage include, but are not limited to:

- * Source code disclosure
- * Browsable directories
- * Log files or backup files in web-accessible directories
- * Unfiltered backend error messages
- * Exception stack traces
- * Server version information
- * Transmission of uninitialized memory containing sensitive data

Recommendations

Configure applications and servers to return generic error messages and to suppress stack traces from being displayed to end users. Ensure that errors generated by the application do not provide insight into specific backend issues.

Remove all backup files, binary archives, alternate versions of files, and test files from web-accessible directories of production servers. The only files that should be present in the application's web document root are files required by the application. Ensure that deployment procedures include the removal of these file types by an administrator. Keep web and application servers fully patched to minimize exposure to publicly-disclosed information leakage vulnerabilities.

Associated Flaws by CWE ID:

➔ Insertion of Sensitive Information into Log File (CWE ID 532)(3 flaws)

Description

A log file was found within the web document root. Log files from web, FTP, or other services should not be stored in the application's document root. These log files may reveal administration pages, user names, or other sensitive data which an attacker could use to access restricted files or services. For example, FTP logs may contain full file path information and FTP account user names. Log files often contain remote IP address information, which could point attackers to additional targets.

Effort to Fix: 1 - Trivial implementation error. Fix is up to 5 lines of code. One hour or less to fix.

Recommendations

Re-configure the service to store log files in an alternate directory that is not available to the web server. These log files should only be accessible by the administrator-level users.

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
214	15	-	Python files within cwis-genai-main.zip	/.../lambda_function.py 26	
213	15	-	Python files within cwis-genai-main.zip	/.../lambda_function.py 34	
211	14	-	Python files within cwis-genai-main.zip	/.../lambda_function.py 102	

Very Low (0 flaws)

No flaws of this type were found

Info (0 flaws)

No flaws of this type were found

About Veracode's Methodology

The Veracode platform uses static and dynamic analysis (for web applications) to identify software security flaws in your applications. Using both static and dynamic analysis helps reduce false negatives and detect a broader range of security flaws. Veracode static analysis models the application into an intermediate representation, which is then analyzed for security flaws using a set of automated security tests. Dynamic analysis uses an automated penetration testing technique to detect security flaws at runtime. Once the automated process is complete, a security technician verifies the output to ensure the lowest false positive rates in the industry. The end result is an accurate list of security flaws for the classes of automated scans applied to the application.

Veracode Rating System Using Multiple Analysis Techniques

Higher assurance applications require more comprehensive analysis to accurately score their security quality. Because each analysis technique (automated static, automated dynamic, manual penetration testing or manual review) has differing false negative (FN) rates for different types of security flaws, any single analysis technique or even combination of techniques is bound to produce a certain level of false negatives. Some false negatives are acceptable for lower business critical applications, so a less expensive analysis using only one or two analysis techniques is acceptable. At higher business criticality the FN rate should be close to zero, so multiple analysis techniques are recommended.

Application Security Policies

The Veracode platform allows an organization to define and enforce a uniform application security policy across all applications in its portfolio. The elements of an application security policy include the target Veracode Level for the application; types of flaws that should not be in the application (which may be defined by flaw severity, flaw category, CWE, or a common standard including OWASP, CWE/SANS Top 25, or PCI); minimum Veracode security score; required scan types and frequencies; and grace period within which any policy-relevant flaws should be fixed.

Policy constraints

Policies have three main constraints that can be applied: rules, required scans, and remediation grace periods.

Evaluating applications against a policy

When an application is evaluated against a policy, it can receive one of four assessments:

Not assessed The application has not yet had a scan published

Passed The application has passed all the aspects of the policy, including rules, required scans, and grace period.

Did not pass The application has not completed all required scans; has not achieved the target Veracode Level; or has one or more policy relevant flaws that have exceeded the grace period to fix.

Conditional pass The application has one or more policy relevant flaws that have not yet exceeded the grace period to fix.

Understand Veracode Levels

The Veracode Level (VL) achieved by an application is determined by type of testing performed on the application, and the severity and types of flaws detected. A minimum security score (defined below) is also required for each level.

There are five Veracode Levels denoted as VL1, VL2, VL3, VL4, and VL5. VL1 is the lowest level and is achieved by demonstrating that security testing, automated static or dynamic, is utilized during the SDLC. VL5 is the highest level and is achieved by performing automated and manual testing and removing all significant flaws. The Veracode Levels VL2, VL3, and VL4 form a continuum of increasing software assurance between VL1 and VL5.

For IT staff operating applications, Veracode Levels can be used to set application security policies. For deployment scenarios of different business criticality, differing VLs should be made requirements. For example, the policy for applications that handle credit card transactions, and therefore have PCI compliance requirements, should be VL5. A medium business criticality internal application could have a policy requiring VL3.

Software developers can decide which VL they want to achieve based on the requirements of their customers. Developers of software that is mission critical to most of their customers will want to achieve VL5. Developers of general purpose business software may want

to achieve VL3 or VL4. Once the software has achieved a Veracode Level it can be communicated to customers through a Veracode Report or through the Veracode Directory on the Veracode web site.

Criteria for achieving Veracode Levels

The following table defines the details to achieve each Veracode Level. The criteria for all columns: Flaw Severities Not Allowed, Flaw Categories not Allowed, Testing Required, and Minimum Score.

*Dynamic is only an option for web applications.

Veracode Level	Flaw Severities Not Allowed	Testing Required*	Minimum Score
VL5	V.High, High, Medium	Static AND Manual	90
VL4	V.High, High, Medium	Static	80
VL3	V.High, High	Static	70
VL2	V.High	Static OR Dynamic OR Manual	60
VL1		Static OR Dynamic OR Manual	

When multiple testing techniques are used it is likely that not all testing will be performed on the exact same build. If that is the case the latest test results from a particular technique will be used to calculate the current Veracode Level. After 6 months test results will be deemed out of date and will no longer be used to calculate the current Veracode Level.

Business Criticality

The foundation of the Veracode rating system is the concept that more critical applications require higher security quality scores to be acceptable risks. Less business critical applications can tolerate lower security quality. The business criticality is dictated by the typical deployed environment and the value of data used by the application. Factors that determine business criticality are: reputation damage, financial loss, operational risk, sensitive information disclosure, personal safety, and legal violations.

US. Govt. OMB Memorandum M-04-04; NIST FIPS Pub. 199

Business Criticality

Description

Very High	Mission critical for business/safety of life and limb on the line
High	Exploitation causes serious brand damage and financial loss with long term business impact
Medium	Applications connected to the internet that process financial or private customer information
Low	Typically internal applications with non-critical business impact
Very Low	Applications with no material business impact

Business Criticality Definitions

Very High (BC5) This is typically an application where the safety of life or limb is dependent on the system; it is mission critical the application maintain 100% availability for the long term viability of the project or business. Examples are control software for industrial, transportation or medical equipment or critical business systems such as financial trading systems.

High (BC4) This is typically an important multi-user business application reachable from the internet and is critical that the application maintain high availability to accomplish its mission. Exploitation of high criticality applications cause serious brand damage and business/financial loss and could lead to long term business impact.

Medium (BC3) This is typically a multi-user application connected to the internet or any system that processes financial or private customer information. Exploitation of medium criticality applications typically result in material business impact resulting

in some financial loss, brand damage or business liability. An example is a financial services company's internal 401K management system.

Low (BC2) This is typically an internal only application that requires low levels of application security such as authentication to protect access to non-critical business information and prevent IT disruptions. Exploitation of low criticality applications may lead to minor levels of inconvenience, distress or IT disruption. An example internal system is a conference room reservation or business card order system.

Very Low (BC1) Applications that have no material business impact should its confidentiality, data integrity and availability be affected. Code security analysis is not required for applications at this business criticality, and security spending should be directed to other higher criticality applications.

Scoring Methodology

The Veracode scoring system, Security Quality Score, is built on the foundation of two industry standards, the Common Weakness Enumeration (CWE) and Common Vulnerability Scoring System (CVSS). CWE provides the dictionary of security flaws and CVSS provides the foundation for computing severity, based on the potential Confidentiality, Integrity and Availability impact of a flaw if exploited.

The Security Quality Score is a single score from 0 to 100, where 0 is the most insecure application and 100 is an application with no detectable security flaws. The score calculation includes non-linear factors so that, for instance, a single Severity 5 flaw is weighted more heavily than five Severity 1 flaws, and so that each additional flaw at a given severity contributes progressively less to the score.

Veracode assigns a severity level to each flaw type based on three foundational application security requirements — Confidentiality, Integrity and Availability. Each of the severity levels reflects the potential business impact if a security breach occurs across one or more of these security dimensions.

Confidentiality Impact

According to CVSS, this metric measures the impact on confidentiality if an exploit should occur using the vulnerability on the target system. At the weakness level, the scope of the Confidentiality in this model is within an application and is measured at three levels of impact -None, Partial and Complete.

Integrity Impact

This metric measures the potential impact on integrity of the application being analyzed. Integrity refers to the trustworthiness and guaranteed veracity of information within the application. Integrity measures are meant to protect data from unauthorized modification. When the integrity of a system is sound, it is fully proof from unauthorized modification of its contents.

Availability Impact

This metric measures the potential impact on availability if a successful exploit of the vulnerability is carried out on a target application. Availability refers to the accessibility of information resources. Almost exclusive to this domain are denial-of-service vulnerabilities. Attacks that compromise authentication and authorization for application access, application memory, and administrative privileges are examples of impact on the availability of an application.

Security Quality Score Calculation

The overall Security Quality Score is computed by aggregating impact levels of all weaknesses within an application and representing the score on a 100 point scale. This score does not predict vulnerability potential as much as it enumerates the security weaknesses and their impact levels within the application code.

The Raw Score formula puts weights on each flaw based on its impact level. These weights are exponential and determined by empirical analysis by Veracode's application security experts with validation from industry experts. The score is normalized to a scale of 0 to 100, where a score of 100 is an application with 0 detected flaws using the analysis technique for the application's business criticality.

Understand Severity, Exploitability, and Remediation Effort

Severity and exploitability are two different measures of the seriousness of a flaw. Severity is defined in terms of the potential impact to confidentiality, integrity, and availability of the application as defined in the CVSS, and exploitability is defined in terms of the likelihood

or ease with which a flaw can be exploited. A high severity flaw with a high likelihood of being exploited by an attacker is potentially more dangerous than a high severity flaw with a low likelihood of being exploited.

Remediation effort, also called Complexity of Fix, is a measure of the likely effort required to fix a flaw. Together with severity, the remediation effort is used to give Fix First guidance to the developer.

Veracode Flaw Severities

Veracode flaw severities are defined as follows:

Severity	Description
Very High	The offending line or lines of code is a very serious weakness and is an easy target for an attacker. The code should be modified immediately to avoid potential attacks.
High	The offending line or lines of code have significant weakness, and the code should be modified immediately to avoid potential attacks.
Medium	A weakness of average severity. These should be fixed in high assurance software. A fix for this weakness should be considered after fixing the very high and high for medium assurance software.
Low	This is a low priority weakness that will have a small impact on the security of the software. Fixing should be consideration for high assurance software. Medium and low assurance software can ignore these flaws.
Very Low	Minor problems that some high assurance software may want to be aware of. These flaws can be safely ignored in medium and low assurance software.
Informational	Issues that have no impact on the security quality of the application but which may be of interest to the reviewer.

Informational findings

Informational severity findings are items observed in the analysis of the application that have no impact on the security quality of the application but may be interesting to the reviewer for other reasons. These findings may include code quality issues, API usage, and other factors.

Informational severity findings have no impact on the security quality score of the application and are not included in the summary tables of flaws for the application.

Exploitability

Each flaw instance in a static scan may receive an exploitability rating. The rating is an indication of the intrinsic likelihood that the flaw may be exploited by an attacker. Veracode recommends that the exploitability rating be used to prioritize flaw remediation within a particular group of flaws with the same severity and difficulty of fix classification.

The possible exploitability ratings include:

Exploitability	Description
V. Unlikely	Very unlikely to be exploited
Unlikely	Unlikely to be exploited

Exploitability	Description
Neutral	Neither likely nor unlikely to be exploited.
Likely	Likely to be exploited
V. Likely	Very likely to be exploited

Note: All reported flaws found via dynamic scans are assumed to be exploitable, because the dynamic scan actually executes the attack in question and verifies that it is valid.

Effort/Complexity of Fix

Each flaw instance receives an effort/complexity of fix rating based on the classification of the flaw. The effort/complexity of fix rating is given on a scale of 1 to 5, as follows:

Effort/Complexity of Fix	Description
5	Complex design error. Requires significant redesign.
4	Simple design error. Requires redesign and up to 5 days to fix.
3	Complex implementation error. Fix is approx. 51-500 lines of code. Up to 5 days to fix.
2	Implementation error. Fix is approx. 6-50 lines of code. 1 day to fix.
1	Trivial implementation error. Fix is up to 5 lines of code. One hour or less to fix.

Flaw Types by Severity Level

The flaw types by severity level table provides a summary of flaws found in the application by Severity and Category. The table puts the Security Quality Score into context by showing the specific breakout of flaws by severity, used to compute the score as described above. If multiple analysis techniques are used, the table includes a breakout of all flaws by category and severity for each analysis type performed.

Flaws by Severity

The flaws by severity chart shows the distribution of flaws by severity. An application can get a mediocre security rating by having a few high risk flaws or many medium risk flaws.

Flaws in Common Modules

The flaws in common modules listing shows a summary of flaws in shared dependency modules in this application. A shared dependency is a dependency that is used by more than one analyzed module. Each module is listed with the number of executables that consume it as a dependency and a summary of the impact on the application's security score of the flaws found in the dependency.

The score impact represents the amount that the application score would increase if all the flaws in the shared dependency module were fixed. This information can be used to focus remediation efforts on common modules with a higher impact on the application security score.

Only common modules that were uploaded with debug information are included in the Flaws in Common Modules listing.

Action Items

The Action Items section of the report provides guidance on the steps required to bring the application to a state where it passes its assigned policy. These steps may include fixing or mitigating flaws or performing additional scans. The section also includes best practice recommendations to improve the security quality of the application.

Common Weakness Enumeration (CWE)

The Common Weakness Enumeration (CWE) is an industry standard classification of types of software weaknesses, or flaws, that can lead to security problems. CWE is widely used to provide a standard taxonomy of software errors. Every flaw in a Veracode report is classified according to a standard CWE identifier.

More guidance and background about the CWE is available at <http://cwe.mitre.org/data/index.html>.

About Manual Assessments

The Veracode platform can include the results from a manual assessment (usually a penetration test or code review) as part of a report. These results differ from the results of automated scans in several important ways, including objectives, attack vectors, and common attack patterns.

A manual penetration assessment is conducted to observe the application code in a run-time environment and to simulate real-world attack scenarios. Manual testing is able to identify design flaws, evaluate environmental conditions, compound multiple lower risk flaws into higher risk vulnerabilities, and determine if identified flaws affect the confidentiality, integrity, or availability of the application.

Objectives

The stated objectives of a manual penetration assessment are:

- Perform testing, using proprietary and/or public tools, to determine whether it is possible for an attacker to:
- Circumvent authentication and authorization mechanisms
- Escalate application user privileges
- Hijack accounts belonging to other users
- Violate access controls placed by the site administrator
- Alter data or data presentation
- Corrupt application and data integrity, functionality and performance
- Circumvent application business logic
- Circumvent application session management
- Break or analyze use of cryptography within user accessible components
- Determine possible extent access or impact to the system by attempting to exploit vulnerabilities
- Score vulnerabilities using the Common Vulnerability Scoring System (CVSS)
- Provide tactical recommendations to address security issues of immediate consequence

Provide strategic recommendations to enhance security by leveraging industry best practices

Attack vectors

In order to achieve the stated objectives, the following tests are performed as part of the manual penetration assessment, when applicable to the platforms and technologies in use:

- Cross Site Scripting (XSS)
- SQL Injection
- Command Injection
- Cross Site Request Forgery (CSRF)
- Authentication/Authorization Bypass
- Session Management testing, e.g. token analysis, session expiration, and logout effectiveness
- Account Management testing, e.g. password strength, password reset, account lockout, etc.
- Directory Traversal
- Response Splitting
- Stack/Heap Overflows
- Format String Attacks

- Cookie Analysis
- Server Side Includes Injection
- Remote File Inclusion
- LDAP Injection
- XPATH Injection
- Internationalization attacks
- Denial of Service testing at the application layer only
- AJAX Endpoint Analysis
- Web Services Endpoint Analysis
- HTTP Method Analysis
- SSL Certificate and Cipher Strength Analysis
- Forced Browsing

CAPEC Attack Pattern Classification

The following attack pattern classifications are used to group similar application flaws discovered during manual penetration testing. Attack patterns describe the general methods employed to access and exploit the specific weaknesses that exist within an application. CAPEC (Common Attack Pattern Enumeration and Classification) is an effort led by Cigital, Inc. and is sponsored by the United States Department of Homeland Security's National Cyber Security Division.

Abuse of Functionality

Exploitation of business logic errors or misappropriation of programmatic resources. Application functions are developed to specifications with particular intentions, and these types of attacks serve to undermine those intentions.

Examples:

- Exploiting password recovery mechanisms
- Accessing unpublished or test APIs
- Cache poisoning

Spoofing

Impersonation of entities or trusted resources. A successful attack will present itself to a verifying entity with an acceptable level of authenticity.

Examples:

- Man in the middle attacks
- Checksum spoofing
- Phishing attacks

Probabilistic Techniques

Using predictive capabilities or exhaustive search techniques in order to derive or manipulate sensitive information. Attacks capitalize on the availability of computing resources or the lack of entropy within targeted components.

Examples:

- Password brute forcing
- Cryptanalysis
- Manipulation of authentication tokens

Exploitation of Authentication

Circumventing authentication requirements to access protected resources. Design or implementation flaws may allow authentication checks to be ignored, delegated, or bypassed.

Examples:

- Cross-site request forgery
- Reuse of session identifiers
- Flawed authentication protocol

Resource Depletion

Affecting the availability of application components or resources through symmetric or asymmetric consumption. Unrestricted access to computationally expensive functions or implementation flaws that affect the stability of the application can be targeted by an attacker in order to cause denial of service conditions.

Examples:

- Flooding attacks
- Unlimited file upload size
- Memory leaks

Exploitation of Privilege/Trust

Undermining the application's trust model in order to gain access to protected resources or gain additional levels of access as defined by the application. Applications that implicitly extend trust to resources or entities outside of their direct control are susceptible to attack.

Examples:

- Insufficient access control lists
- Circumvention of client side protections
- Manipulation of role identification information

Injection

Inserting unexpected inputs to manipulate control flow or alter normal business processing. Applications must contain sufficient data validation checks in order to sanitize tainted data and prevent malicious, external control over internal processing.

Examples:

- SQL Injection
- Cross-site scripting
- XML Injection

Data Structure Attacks

Supplying unexpected or excessive data that results in more data being written to a buffer than it is capable of holding. Successful attacks of this class can result in arbitrary command execution or denial of service conditions.

Examples:

- Buffer overflow
- Integer overflow
- Format string overflow

Data Leakage Attacks

Recovering information exposed by the application that may itself be confidential or may be useful to an attacker in discovering or exploiting other weaknesses. A successful attack may be conducted passive observation or active interception methods. This attack pattern often manifests itself in the form of applications that expose sensitive information within error messages.

Examples:

- Sniffing clear-text communication protocols
- Stack traces returned to end users
- Sensitive information in HTML comments

Resource Manipulation

Manipulating application dependencies or accessed resources in order to undermine security controls and gain unauthorized access to protected resources. Applications may use tainted data when constructing paths to local resources or when constructing processing environments.

Examples:

- Carriage Return Line Feed log file injection
- File retrieval via path manipulation
- User specification of configuration files

Time and State Attacks

Undermining state condition assumptions made by the application or capitalizing on time delays between security checks and performed operations. An application that does not enforce a required processing sequence or does not handle concurrency adequately will be susceptible to these attack patterns.

Examples:

- Bypassing intermediate form processing steps
- Time-of-check and time-of-use race conditions
- Deadlock triggering to cause a denial of service

Terms of Use

Use and distribution of this report are governed by the agreement between Veracode and its customer. In particular, this report and the results in the report cannot be used publicly in connection with Veracode's name without written permission.

Appendix A: Changes from Last Scan

Latest Scan		Prior Scan	
Static Scan			
Scan Name:	cwis-genai-main-10 Sep 2026 Static	Scan Name:	ValidationScan - cwis-genai - Main - 07-17-26
Completed:	9/10/26	Completed:	7/20/26
Score:	73	Score:	71

Flaws not detected in current scan

The following is a list of all flaws found in the prior scan of this application that were not detected in the current scan.

High (2 flaws)  **Fix Required by Policy**

→ Credentials Management(2 flaws)

Associated Flaws by CWE ID:

→ Use of Hard-coded Password (CWE ID 259)(2 flaws)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
 54	5	-	Python Files	.../helper/aws_embeddings.py 321	
 53	5	-	Python Files	.../helper/aws_embeddings.py 322	

Medium (91 flaws)

→ Authorization Issues(1 flaw)

Associated Flaws by CWE ID:

→ Improper Control of Resource Identifiers ('Resource Injection') (CWE ID 99)(1 flaw)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
141	17	-	Python Files	.../run_from_excel_bedrock.py 918	

→ CRLF Injection(83 flaws)

Associated Flaws by CWE ID:

→ Improper Output Neutralization for Logs (CWE ID 117)(83 flaws)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
148	17	-	Python Files	.../run_from_excel_bedrock.py 210	
138	17	-	Python Files	.../run_from_excel_bedrock.py 271	
140	17	-	Python Files	.../run_from_excel_bedrock.py 287	
137	17	-	Python Files	.../run_from_excel_bedrock.py 295	
139	17	-	Python Files	.../run_from_excel_bedrock.py 304	
136	17	-	Python Files	.../run_from_excel_bedrock.py 307	
146	17	-	Python Files	.../run_from_excel_bedrock.py 845	
143	17	-	Python Files	.../run_from_excel_bedrock.py 849	
144	17	-	Python Files	.../run_from_excel_bedrock.py 850	
142	17	-	Python Files	.../run_from_excel_bedrock.py 913	
134	17	-	Python Files	.../run_from_excel_bedrock.py 1117	
129	17	-	Python Files	.../run_from_excel_bedrock.py 1176	
128	17	-	Python Files	.../run_from_excel_bedrock.py 1177	
127	17	-	Python Files	.../run_from_excel_bedrock.py 1178	
126	17	-	Python Files	.../run_from_excel_bedrock.py 1179	
125	17	-	Python Files	.../run_from_excel_bedrock.py 1180	
124	17	-	Python Files	.../run_from_excel_bedrock.py 1181	
123	17	-	Python Files	.../run_from_excel_bedrock.py 1182	
122	17	-	Python Files	.../run_from_excel_bedrock.py 1183	
95	17	-	Python Files	.../run_from_excel_bedrock.py 1201	
101	17	-	Python Files	.../run_from_excel_bedrock.py 1202	
121	17	-	Python Files	.../run_from_excel_bedrock.py 1205	
94	17	-	Python Files	.../run_from_excel_bedrock.py 1212	
100	17	-	Python Files	.../run_from_excel_bedrock.py 1213	
99	17	-	Python Files	.../run_from_excel_bedrock.py 1221	
93	17	-	Python Files	.../run_from_excel_bedrock.py 1225	
92	17	-	Python Files	.../run_from_excel_bedrock.py 1230	
98	17	-	Python Files	.../run_from_excel_bedrock.py 1238	
120	17	-	Python Files	.../run_from_excel_bedrock.py 1249	
97	17	-	Python Files	.../run_from_excel_bedrock.py 1268	
108	17	-	Python Files	.../run_from_excel_bedrock.py 1269	
107	17	-	Python Files	.../run_from_excel_bedrock.py 1275	
106	17	-	Python Files	.../run_from_excel_bedrock.py 1280	
105	17	-	Python Files	.../run_from_excel_bedrock.py 1281	
96	17	-	Python Files	.../run_from_excel_bedrock.py 1282	

Flaw Id	Module #	Class #	Module	Location	Fix By
104	17	-	Python Files	.../run_from_excel_bedrock.py 1290	
119	17	-	Python Files	.../run_from_excel_bedrock.py 1292	
70	17	-	Python Files	.../run_from_excel_bedrock.py 1295	
69	17	-	Python Files	.../run_from_excel_bedrock.py 1298	
68	17	-	Python Files	.../run_from_excel_bedrock.py 1299	
67	17	-	Python Files	.../run_from_excel_bedrock.py 1300	
118	17	-	Python Files	.../run_from_excel_bedrock.py 1302	
117	17	-	Python Files	.../run_from_excel_bedrock.py 1320	
89	17	-	Python Files	.../run_from_excel_bedrock.py 1336	
116	17	-	Python Files	.../run_from_excel_bedrock.py 1345	
91	17	-	Python Files	.../run_from_excel_bedrock.py 1351	
88	17	-	Python Files	.../run_from_excel_bedrock.py 1353	
115	17	-	Python Files	.../run_from_excel_bedrock.py 1368	
85	17	-	Python Files	.../run_from_excel_bedrock.py 1382	
114	17	-	Python Files	.../run_from_excel_bedrock.py 1388	
113	17	-	Python Files	.../run_from_excel_bedrock.py 1391	
102	17	-	Python Files	.../run_from_excel_bedrock.py 1392	
103	17	-	Python Files	.../run_from_excel_bedrock.py 1393	
82	17	-	Python Files	.../run_from_excel_bedrock.py 1394	
112	17	-	Python Files	.../run_from_excel_bedrock.py 1395	
84	17	-	Python Files	.../run_from_excel_bedrock.py 1396	
83	17	-	Python Files	.../run_from_excel_bedrock.py 1397	
87	17	-	Python Files	.../run_from_excel_bedrock.py 1398	
86	17	-	Python Files	.../run_from_excel_bedrock.py 1399	
111	17	-	Python Files	.../run_from_excel_bedrock.py 1401	
110	17	-	Python Files	.../run_from_excel_bedrock.py 1420	
90	17	-	Python Files	.../run_from_excel_bedrock.py 1426	
109	17	-	Python Files	.../run_from_excel_bedrock.py 1461	
81	17	-	Python Files	.../run_from_excel_bedrock.py 1462	
80	17	-	Python Files	.../run_from_excel_bedrock.py 1463	
79	17	-	Python Files	.../run_from_excel_bedrock.py 1464	
78	17	-	Python Files	.../run_from_excel_bedrock.py 1465	
77	17	-	Python Files	.../run_from_excel_bedrock.py 1466	
66	17	-	Python Files	.../run_from_excel_bedrock.py 1471	
71	17	-	Python Files	.../run_from_excel_bedrock.py 1481	
75	17	-	Python Files	.../run_from_excel_bedrock.py 1482	
74	17	-	Python Files	.../run_from_excel_bedrock.py 1483	
73	17	-	Python Files	.../run_from_excel_bedrock.py 1484	

Flaw Id	Module #	Class #	Module	Location	Fix By
72	17	-	Python Files	.../run_from_excel_bedrock.py 1485	
133	17	-	Python Files	.../run_from_excel_bedrock.py 1504	
132	17	-	Python Files	.../run_from_excel_bedrock.py 1505	
131	17	-	Python Files	.../run_from_excel_bedrock.py 1513	
76	17	-	Python Files	.../run_from_excel_bedrock.py 1554	
65	17	-	Python Files	.../run_from_excel_bedrock.py 1579	
64	17	-	Python Files	.../run_from_excel_bedrock.py 1580	
63	17	-	Python Files	.../run_from_excel_bedrock.py 1581	
62	17	-	Python Files	.../run_from_excel_bedrock.py 1582	
61	17	-	Python Files	.../run_from_excel_bedrock.py 1592	

→ Cryptographic Issues(3 flaws)

Associated Flaws by CWE ID:

→ Improper Certificate Validation (CWE ID 295)(1 flaw)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
60	17	-	Python Files	.../run_from_excel_bedrock.py 276	

→ Insufficient Entropy (CWE ID 331)(2 flaws)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
52	4	-	Python Files	.../aws_bedrock_controller.py 47	
51	4	-	Python Files	.../aws_bedrock_controller.py 86	

→ Directory Traversal(4 flaws)

Associated Flaws by CWE ID:

➔ External Control of File Name or Path (CWE ID 73)(4 flaws)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
147	17	-	Python Files	.../run_from_excel_bedrock.py 844	
145	17	-	Python Files	.../run_from_excel_bedrock.py 848	
135	17	-	Python Files	.../run_from_excel_bedrock.py 1115	
130	17	-	Python Files	.../run_from_excel_bedrock.py 1169	

Low (1 flaw)

➔ Information Leakage(1 flaw)

Associated Flaws by CWE ID:

➔ Insertion of Sensitive Information into Log File (CWE ID 532)(1 flaw)

Instances found via Static Scan

Flaw Id	Module #	Class #	Module	Location	Fix By
50	14	-	Python Files	.../lambda_function.py 297	

Appendix B: Referenced Source Files

Id	Filename	Path
1	activity.py	/cwis-genai-main/app/services/orchestrator/api/routers/v1/common/
2	activity.py	/cwis-genai-main/app/services/orchestrator/api/db/
3	auth.tsx	/cwis-genai-main/app/ui/client/src/
4	aws_bedrock_controller.py	cwis-genai-main/app/services/orchestrator/api/controllers/aws/
5	aws_embeddings.py	cwis-genai-main/app/services/orchestrator/helper/
6	aws_s3.py	/cwis-genai-main/app/services/orchestrator/helper/
7	bedrock_judge.py	/cwis-genai-main/tests/eval_judge/
8	index.tsx	/cwis-genai-main/app/ui/client/src/components/InstanceGenerator/
9	index.tsx	/cwis-genai-main/app/ui/client/src/components/DownloadButton/
10	index.tsx	/cwis-genai-main/app/ui/client/src/components/ActivityStatusDropDown/
11	index.tsx	/cwis-genai-main/app/ui/client/src/pages/CaseCopilotGenerator/
12	index.tsx	/cwis-genai-main/app/ui/client/src/pages/ActivityHistoryTable/
13	knowledge.py	/cwis-genai-main/app/services/orchestrator/api/routers/v1/aws/
14	lambda_function.py	cwis-genai-main/app/lambda/knowledge-base-update/
15	lambda_function.py	/cwis-genai-main/app/lambda/update-existing-knowledge/
16	projects.py	/cwis-genai-main/app/services/orchestrator/api/routers/v1/common/
17	run_from_excel_bedrock.py	cwis-genai-main/tests/
18	s3_helper.py	/cwis-genai-main/app/lambda/knowledge-base-update/
19	security.py	/cwis-genai-main/app/services/orchestrator/settings/
20	shared_index.tsx	/cwis-genai-main/app/ui/client/src/components/InstanceGenerator/